

IT PROFESSIONAL PORTFOLIO

Cloud Engineering and Security Projects

PROJECT 17

Create and Attach a RegionLockout SCP for Approved AWS Regions

AWS Organizations | SCPs | Region Restrictions | NotAction

AUTHOR	Michael Salazar
ENVIRONMENT	Personal AWS Lab
VERSION	v1.0.0
RELEASE DATE	July 14, 2026
STATUS	Complete

Executive Summary

Created a customer-managed AWS Organizations Service Control Policy named **RegionLockout**. The policy uses a deny-based region restriction to block non-exempt actions outside **us-west-2** and **us-east-1**, while exempting a list of global or required service actions through **NotAction**. The policy was attached to the **Root** of the AWS Organizations hierarchy so the guardrail is inherited by descendant OUs and member accounts.

Business Problem

AWS regions are isolated management planes. If an organization only intends to operate in a small number of regions, unused regions can create risk because attackers or users may launch resources where security monitoring, guardrails, or cost controls are less mature. A region-lockout SCP reduces that attack surface by denying activity outside approved regions without breaking selected global services.

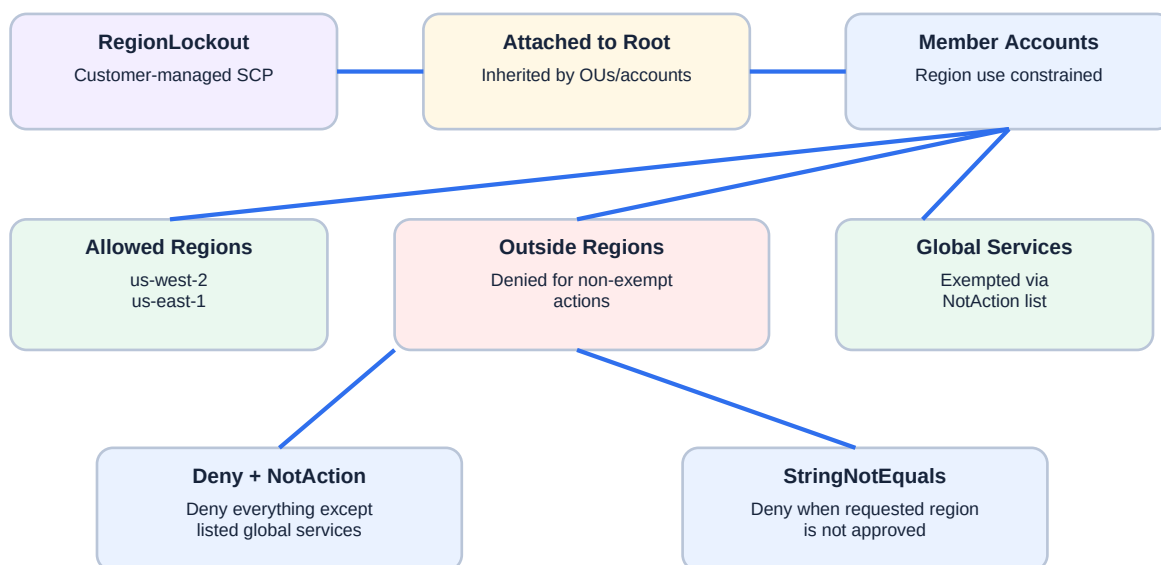
Objectives

- Create a customer-managed SCP named RegionLockout.
- Allow intended regional operation in us-west-2 and us-east-1.
- Deny non-exempt API actions in all other regions.
- Use NotAction so selected global services and required supporting actions remain available.
- Use aws:RequestedRegion with StringNotEquals to block any region not explicitly approved.
- Attach the policy to the organization Root for broad inherited enforcement.

Environment

Cloud Provider	Amazon Web Services (AWS)
Primary Service	AWS Organizations
Policy Type	Service Control Policy (customer-managed)
Policy Name	RegionLockout
Attachment Target	Organization Root
Approved Regions	us-west-2 and us-east-1
Denied Scope	Non-exempt actions when aws:RequestedRegion is not approved
Global Service Handling	Exempted through the NotAction list
Policy Pattern	Deny + NotAction + StringNotEquals
Management Account Note	SCPs do not restrict the AWS Organizations management account

Architecture



The SCP blocks non-exempt API actions when `aws:RequestedRegion` is not `us-east-1` or `us-west-2`.

SCPs do not restrict the AWS Organizations management account.

Figure 1 - RegionLockout SCP inheritance and double-negative policy logic.

Implementation Summary

1. Opened AWS Organizations through the management account access path.
2. Navigated to Policies and selected Service Control Policies.
3. Created a new customer-managed SCP named RegionLockout.
4. Added a description documenting that the policy blocks all regions except `us-west-2` and `us-east-1` while allowing global services.
5. Pasted the JSON policy using a Deny statement with NotAction.
6. Included the approved region list under `aws:RequestedRegion` with StringNotEquals.
7. Saved the policy.
8. Attached RegionLockout to the organization Root target.
9. Validated the policy details and Root target attachment.

PRECISION

This policy does not literally turn AWS regions off. It denies API actions when the requested region is outside the approved list, except for actions explicitly exempted in the NotAction list.

Policy Logic

Effect	Deny	Creates a preventive guardrail that overrides allowed permissions.
NotAction	Global-service and required supporting actions	Means deny everything except the listed actions.
Resource	*	Applies the statement broadly across resources.
Condition	StringNotEquals on aws:RequestedRegion	Triggers the deny when the request is not in the approved region list.
Approved regions	us-east-1 and us-west-2	Requests to these regions are not denied by this condition.
Target	Root	Descendant OUs and member accounts inherit the guardrail.

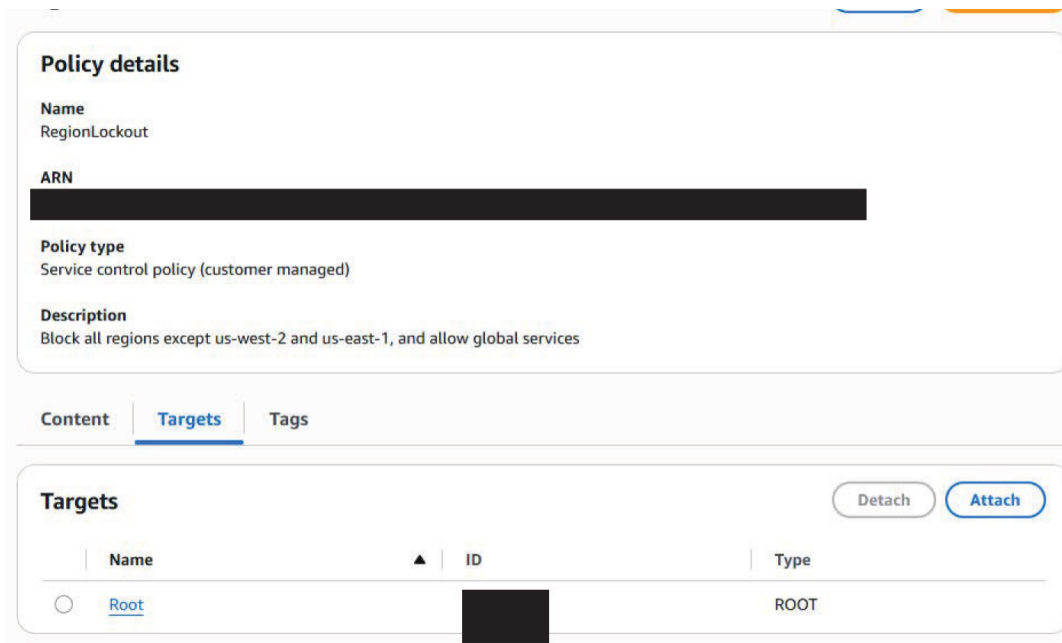
Evidence

Figure 2 - RegionLockout JSON Policy

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyAllOutsideRegions",
      "Effect": "Deny",
      "NotAction": [
        "aws:",
        "aws-marketplace-management:*",
        "aws-marketplace:*",
        "aws-portal:*",
        "budgets:*",
        "ce:*",
        "chime:*",
        "cloudfront:*",
        "config:*",
        "cur:*",
        "directconnect:*",
        "ec2:DescribeRegions",
        "ec2:DescribeTransitGateways",
        "ec2:DescribeVpnGateways",
        "egs:*",
        "globalaccelerator:*",
        "health:*",
        "iam:*",
        "importexport:*",
        "iis:*",
        "iis:analytics:*",
        "networkmanager:*",
        "organizations:*",
        "pricing:*",
        "route53:*",
        "route53domains:*",
        "route53-recovery-cluster:*",
        "route53-recovery-control-config:*",
        "route53-recovery-readiness:*",
        "s3:getAccountPublic*",
        "s3:putAccountPublic*",
        "s3:putAccountPublic*",
        "shield:*",
        "sts:*",
        "support:*",
        "trustedadvisor:*",
        "waf-regional:*",
        "waf:*",
        "wafv2:*",
        "wellarchitected:*"
      ],
      "Resource": "*",
      "Condition": {
        "StringNotEquals": {
          "aws:RequestedRegion": [
            "us-east-1",
            "us-west-2"
          ]
        }
      }
    }
  ]
}
```

The JSON evidence shows the RegionLockout SCP using Sid DenyAllOutsideRegions, Effect Deny, a NotAction exemption list for global services and supporting actions, Resource *, and a StringNotEquals condition on aws:RequestedRegion with us-east-1 and us-west-2 as the approved regions.

Figure 3 - RegionLockout Attached to Organization Root



The redacted policy details evidence shows the customer-managed SCP named RegionLockout with the description 'Block all regions except us-west-2 and us-east-1, and allow global services.' The Targets tab shows Root as the attached target. Sensitive policy and target identifiers were redacted before publication.

Security Analysis

Region restrictions reduce attack surface by preventing most activity in regions the organization does not intend to use.

The Deny statement is intentionally strong. If a member-account identity has permissions through IAM or an SSO permission set, the SCP can still block the action outside approved regions.

Using NotAction prevents the SCP from breaking selected global services that do not behave like normal regional services.

Using StringNotEquals with aws:RequestedRegion is future-resistant because newly launched AWS regions are denied by default unless explicitly added to the approved list.

Attaching the policy to Root creates broad inherited enforcement, but it also means all OUs, including Exceptions, inherit the region restriction unless a later design moves the policy to selected OUs.

Lessons Learned

SCPs define the maximum permissions available to affected member accounts. They do not grant access; they only restrict what otherwise-permitted identities can do.

Double-negative SCP patterns are common in preventive guardrails. Deny plus NotAction means 'deny everything except this list.' Deny plus StringNotEquals means 'deny when this value is not in the allowed list.'

Global services require special handling in region-deny policies. Blocking all non-approved regional requests without exemptions can break services such as IAM, Organizations, Route 53, CloudFront, STS, billing-related

services, and support-related services.

Region-lockout policies should be tested carefully before production rollout because existing workloads or service dependencies may already exist outside the intended region set.

Production Improvements

- Inventory active resources and billing activity across all regions before enforcing region restrictions in production.
- Test RegionLockout in a sandbox OU before applying it to broad production targets.
- Consider attaching the policy to selected OUs instead of Root if Exceptions or incident-response workflows need different behavior.
- Monitor CloudTrail for AccessDenied events caused by region restrictions to identify unexpected usage or required exceptions.
- Review the global-service NotAction list periodically as AWS services and global endpoints evolve.
- Document a change process for adding or removing approved regions.

Skills Demonstrated

Service Control Policies	Region restrictions	AWS Organizations
NotAction	aws:RequestedRegion	Preventive controls
Double-negative policy logic	Global service exemptions	Root target inheritance

Resume Bullet

RESUME	Created and attached an AWS Organizations RegionLockout SCP using Deny, NotAction, and aws:RequestedRegion conditions to restrict member-account activity to us-west-2 and us-east-1 while preserving selected global service functionality.
--------	--

STAR Interview Story

Situation: The AWS organization had a growing multi-account structure and needed a preventive control to reduce exposure in unused regions.

Task: Create a region-restriction SCP that allowed only approved regions while avoiding disruption to global AWS services.

Action: I authored the RegionLockout SCP with a Deny statement, NotAction global-service exemptions, and a StringNotEquals condition for aws:RequestedRegion, then attached it to the organization Root.

Result: The organization now has a root-attached guardrail that blocks most non-exempt activity outside us-east-1 and us-west-2 for descendant accounts.

Version History

v1.0.0	July 14, 2026	Initial documented implementation. Created the RegionLockout customer-managed SCP, configured the Deny + NotAction + aws:RequestedRegion logic to restrict regions to us-west-2 and us-east-1 while preserving global-service access, attached the policy to organization Root, and embedded all provided evidence using portfolio documentation standard v1.0.1.

References

- Cloud Security Lab a Week (S.L.A.W.) - NotWhat?!? Lock Out Regions with a Double Negative SCP.
- User-provided RegionLockout JSON policy evidence.
- User-provided RegionLockout policy target evidence.
- Project 16 - SCP Target Rework and Root Account Recovery.